Rafael Angelo Christianto

STATIC MALWARE ANALYSIS

2025-06-13 - TRAFFIC ANALYSIS EXERCISE: IT'S A TRAP!

Introduction

From this PCAP file I obtained from https://www.malware-traffic-analysis.net/index.html, I hope I can sharpen my knowledge in how malware behaves at a packet-level point of view. And later when I am done with my analysis, I will answer the 4 questions that are included in the webpage of this particular malware.

Below is the information about the packet capture I am analyzing from malware traffic analysis website.

- LAN segment range: **10.6.13[.]0/24** (**10.6.13[.]0** through **10.6.13[.]255**)
- Domain: **massfriction[.]com**
- Active Directory (AD) domain controller: **10.6.13[.]3 - WIN-DQL4WFWJXQ4**
- AD environment name: **MASSFRICTION**
- LAN segment gateway: **10.6.13[.]1**
- LAN segment broadcast address: **10.6.13[.]255**

Methodology

I will be performing the analysis on a Virtual Machine using Wireshark, and see findings I can find and find out what the malware intends to do in the infected machine.

I already downloaded the zip file from the link given below: https://www.malware-traffic-analysis.net/2025/06/13/index.html

If you want to do this, make sure to do it in a Virtual machine or controlled environment, since I will not be responsible for any damage to anyone's laptop due to this project.

Technically, it is possible to install Wireshark on the host machine, but it can be risky as the malware has a possibility to escape out of the packet capture. But it is possible to interact with the packet capture by opening it in Wireshark, but do not extract anything out of the packet capture, and then executing it as it may contain the malware.

Here are some settings I will recommend for the Virtual machine for the best of safety:

- Internal network instead of bridged adapter to keep it isolated
- Turn off shared clipboard

The screenshot I have used for this project is taken by the Snipping Tool from my host Windows machine.

I will also be using VirusTotal from https://www.virustotal.com in order to scan links, whether they are malicious or not. They check it by checking the hash (usually SHA256), and they compare it to the billions of other files, and notice if it is ever marked as malicious.

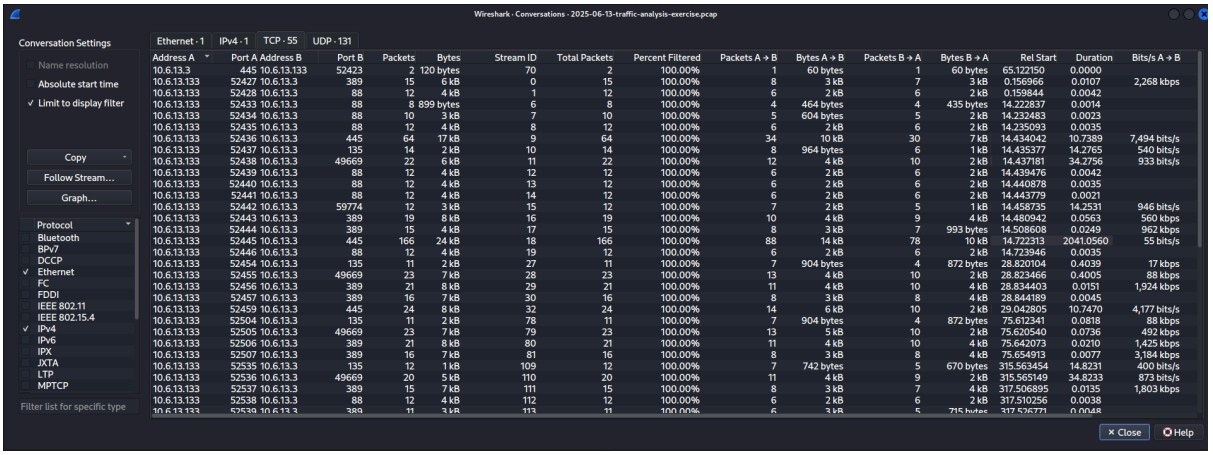
Results

I have extracted the zip file using the unzip command tool, and there is only a PCAP file inside of it. But, below is the sha256 hash for this packet capture file.

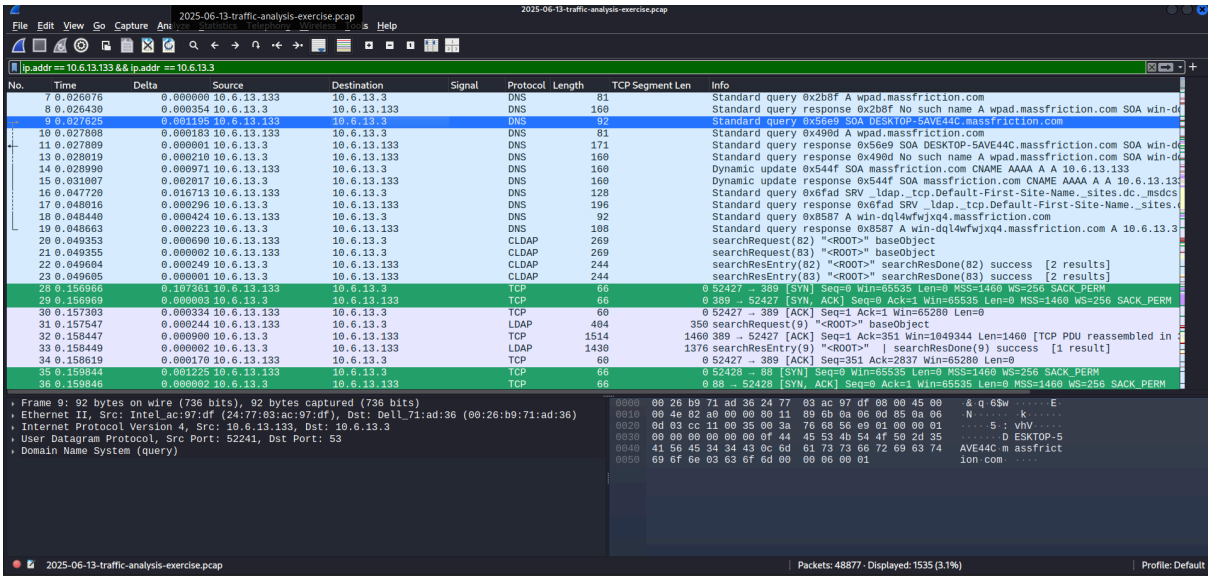
From the TCP conversations in the PCAP, we can see it is only happening between 2 IP addresses, which are

- 10.6.13.13
- 10.6.13.133

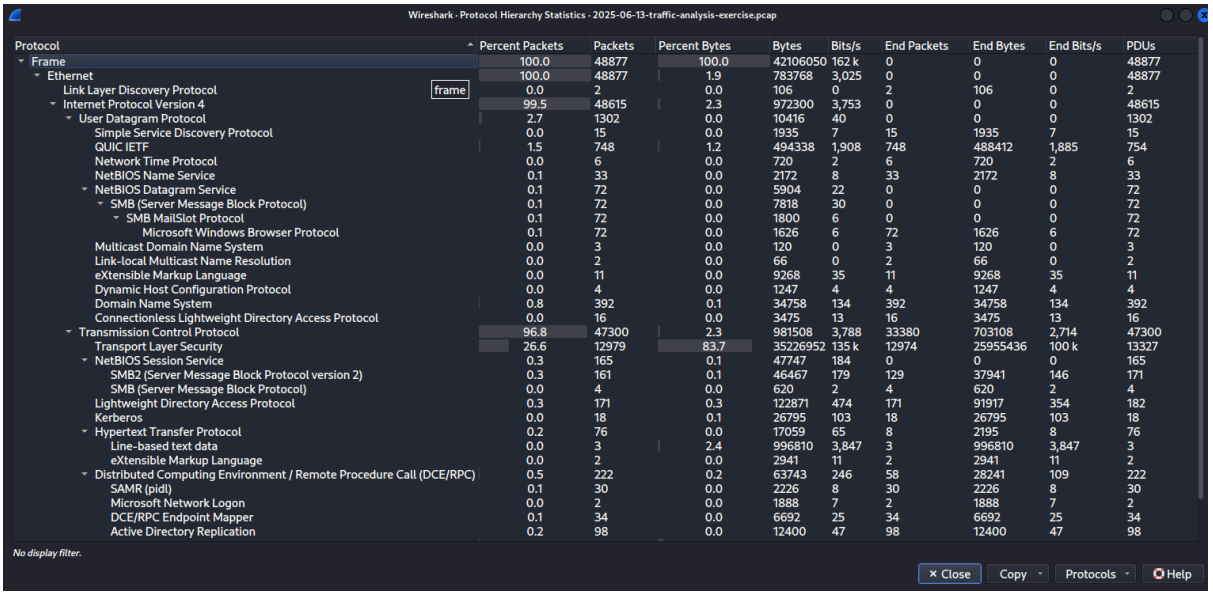
It can also be observed that some of the packets were sent at a very high port number which is suspicious, and some of them were port 445 which is SMB.

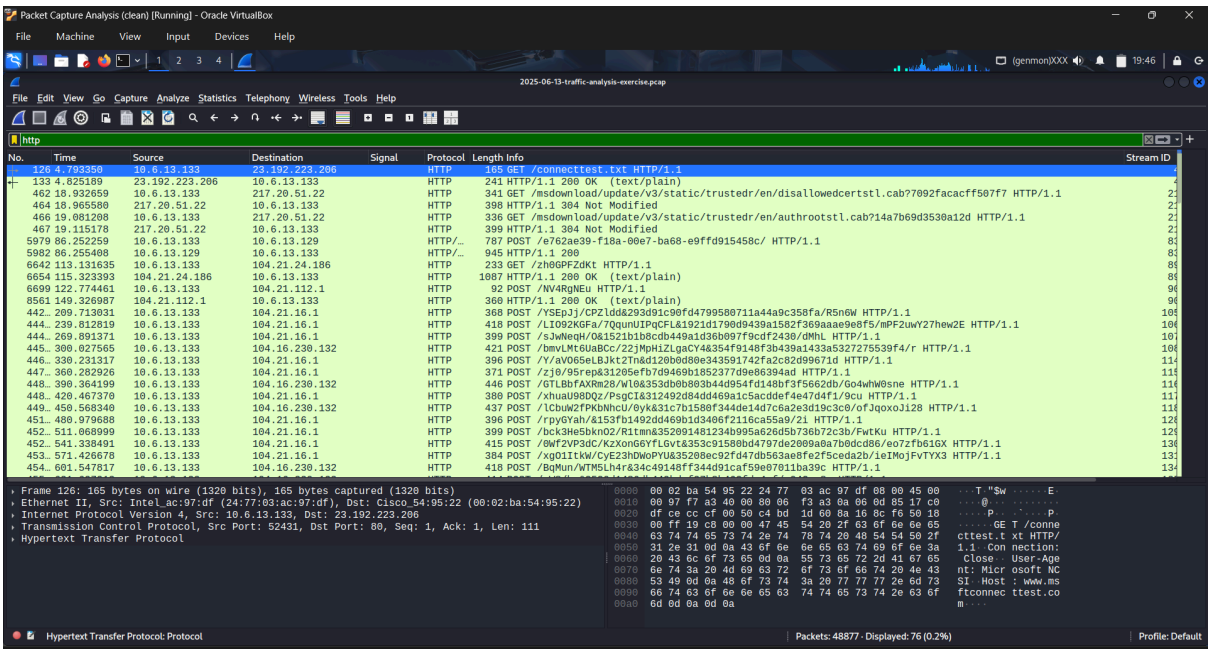


As we can see from the Wireshark screenshot below on packet number 8-12 it is making a DNS query to massfriction.com. With Web-Proxy Auto Discovery which is a technology that allows browsers to detect proxy servers, in this case it is finding for the domain of massfriction.com. And we see a Windows host name which is being resolved, whose name is DESKTOP-5AVE44C who belongs to 10.6.13.133.



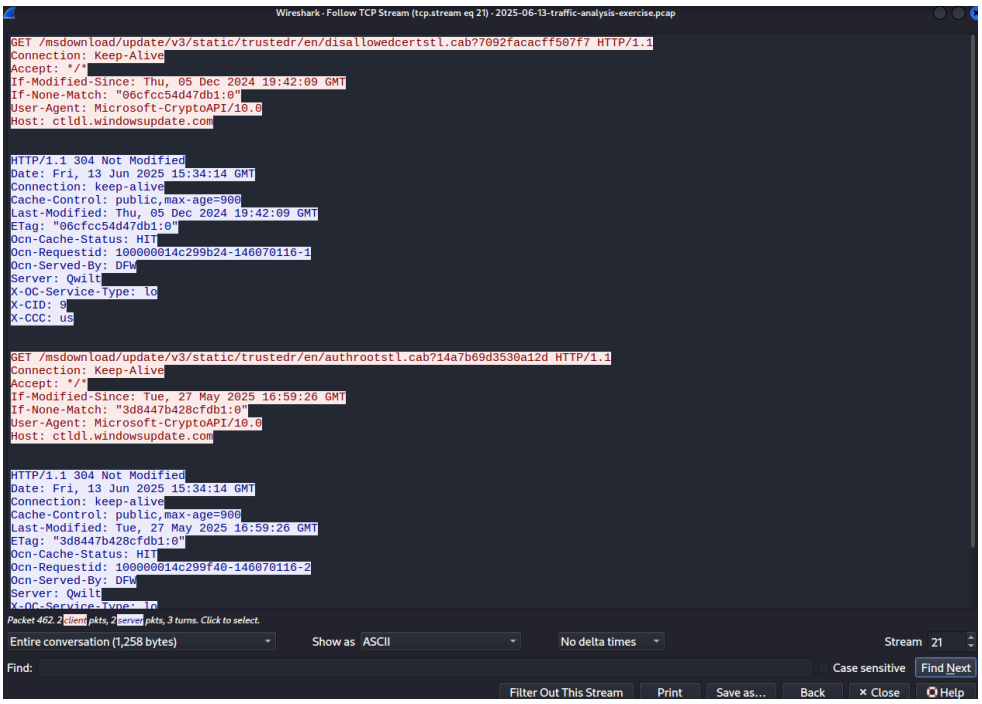
Here is the protocol hierarchy of the packet capture file. And we can see most of the conversations are made under the TCP protocol, approximately around 96%. And specifically, most of them were the protocol of Transport Layer Security (TLS).





After we follow the TCP stream of packet number 462, we can see an odd user agent which is Microsoft Crypto API, which is a web crawler by Microsoft, similar to wget or curl.

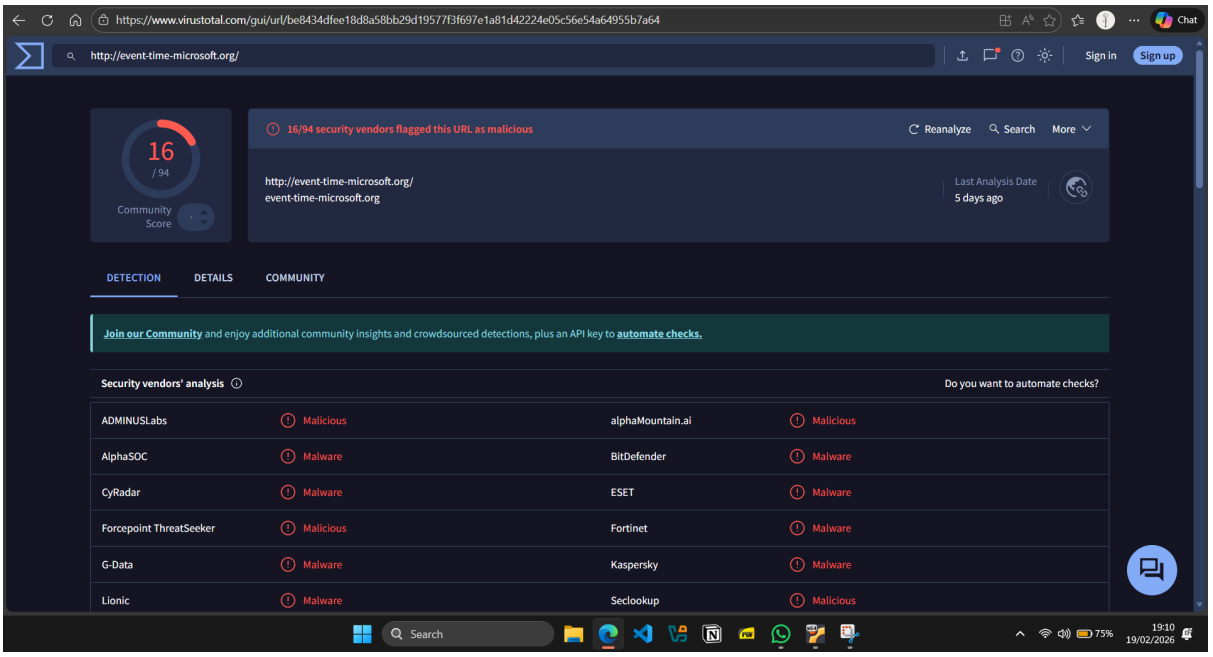
Rafael Angelo Christianto



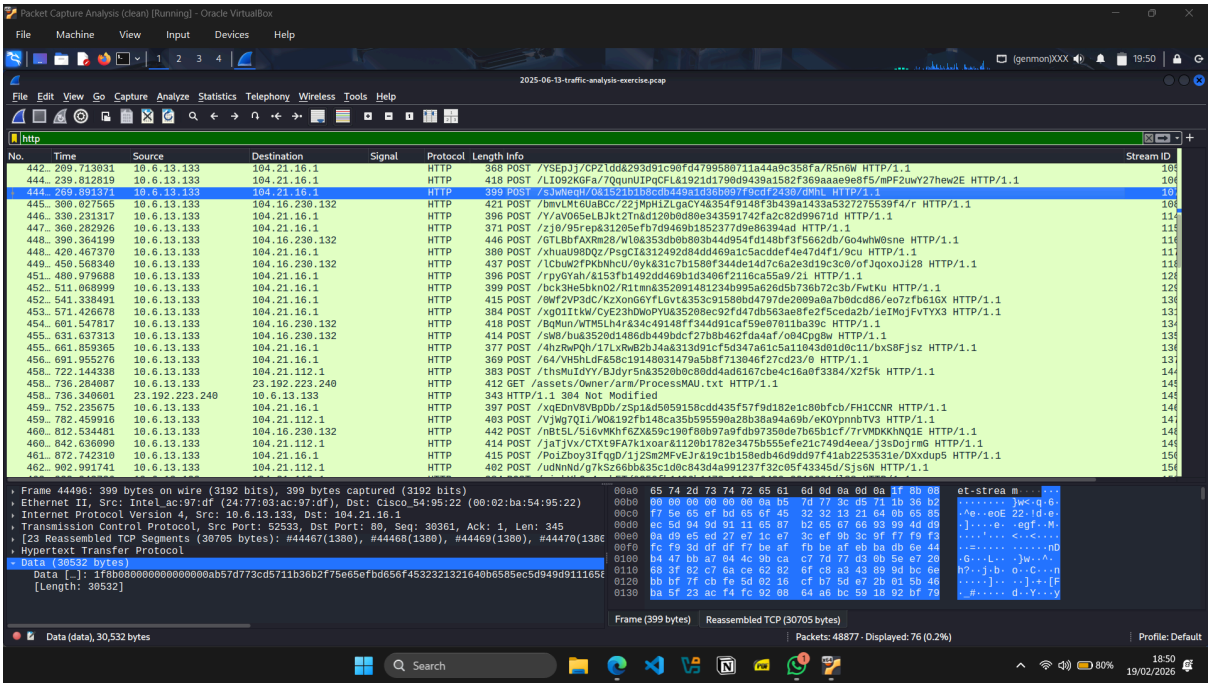
For the image below, this time the user agent is normal but then, the host trying to be reached out is suspicious, which is the: event-time-microsoft.org

Rafael Angelo Christianto

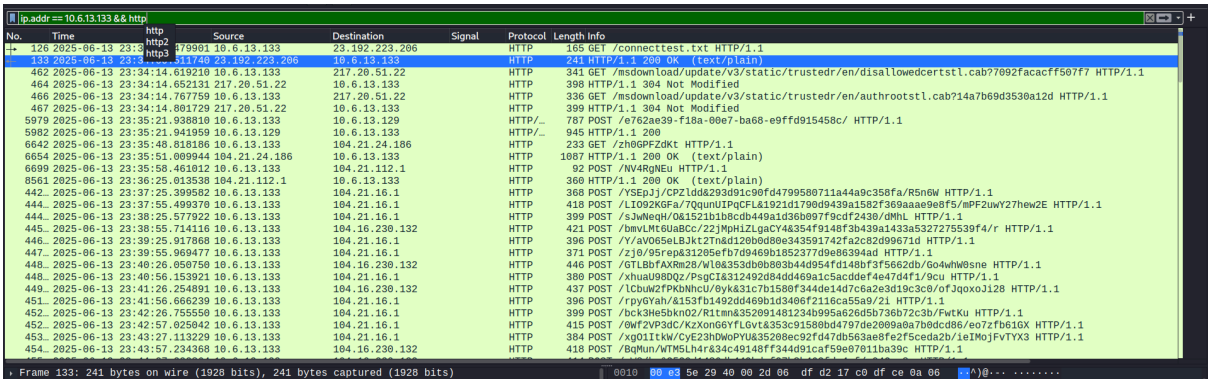
After checking it at VirusTotal, I found it to be malicious.



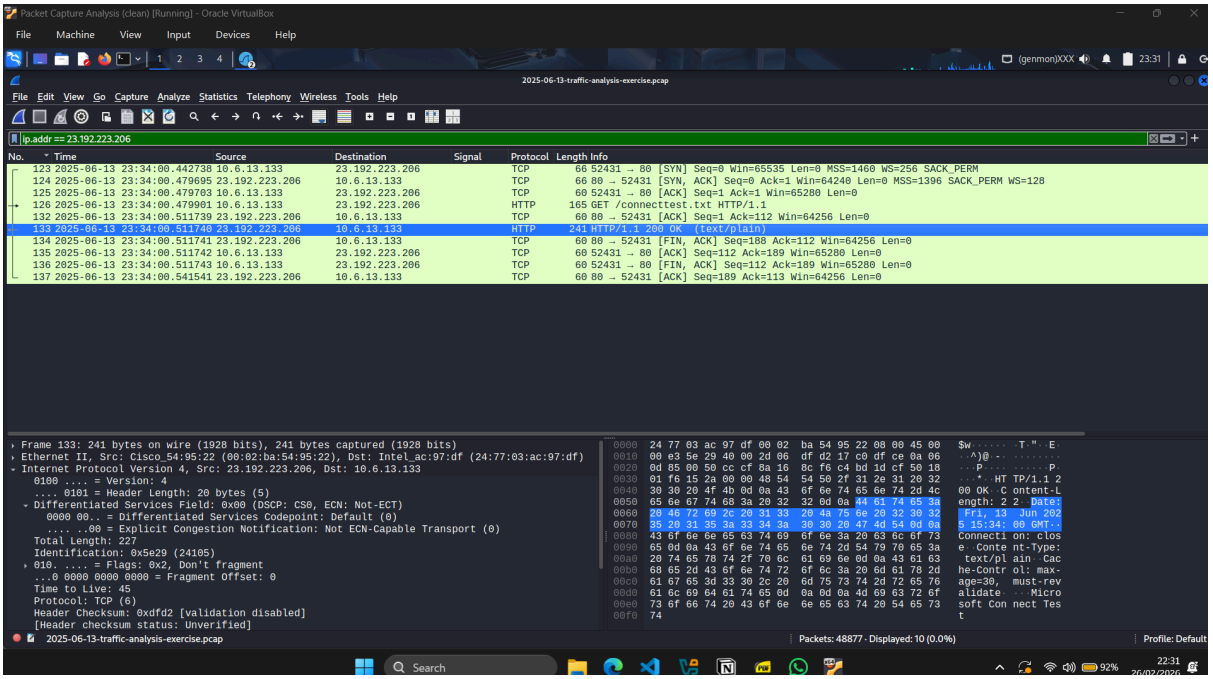
From this image below, we can see a lot of the HTTP requests are POST



Now in the screenshot below, packet number 126 , It says a GET connection to a suspicious named file, which is /connecttest.txt. From the file name it is like testing whether we have an internet connection.

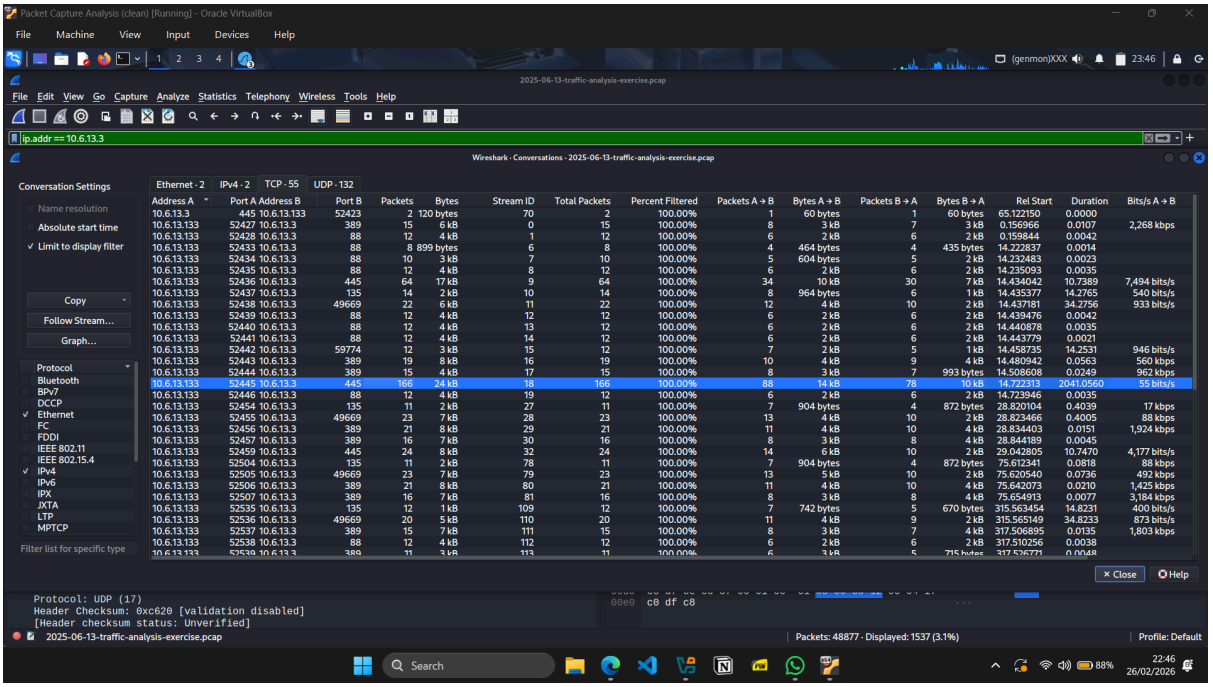


So we can see the destination IP of that packet 126, which is 23.192.223.206, is for Akamai technologies which is a CDN. So I want to filter again the packets who have the IP 23.192.223.206. The image screenshot will be shown below.



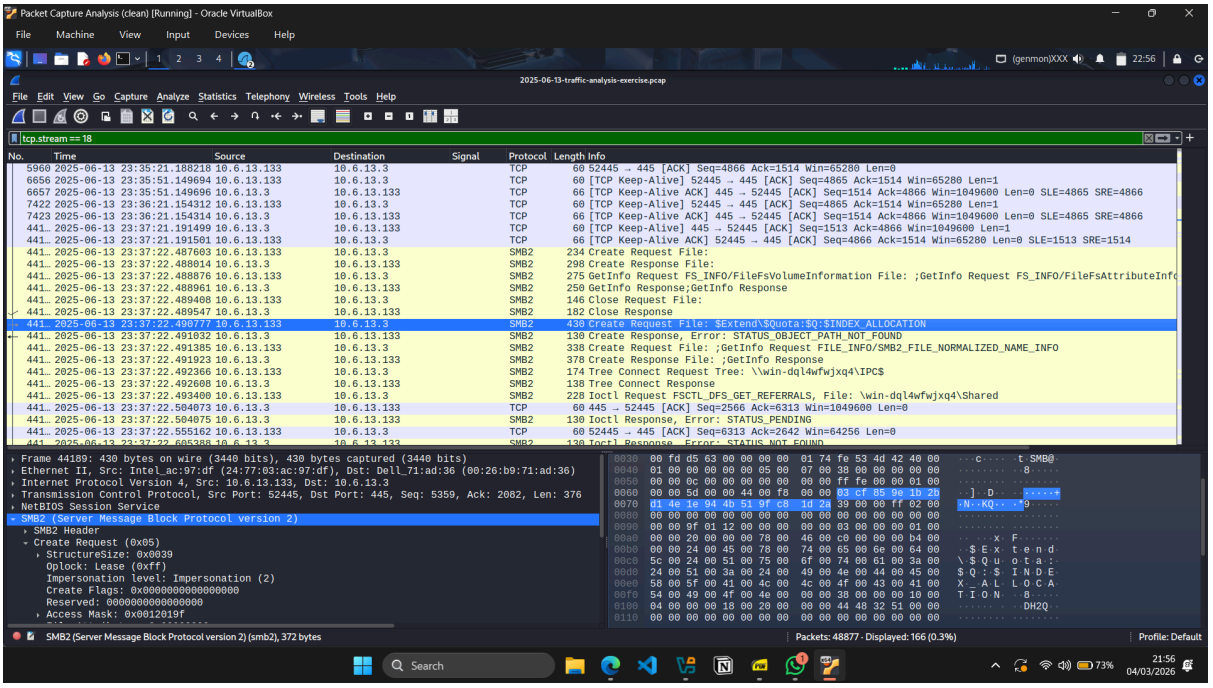
So the first 3 packets (123 - 125) are the opening 3 way handshake packets, and then it starts off from 126 where it gets 10.6.13.133 (infected device) gets the connecttest;txt file and it was successful HTTP GET request seen from 133 success code of 200 which translates to successful. Then the last 4 packets (134 - 137) are the closing packets of the connection between the 2 hosts.

I then checked for possible beaconing or C2 behavior by this malware. I went first by filtering for the malicious IP address, which is the 10.6.13.3 IP address. Then after, I went to Statistics > Conversations. The display will be showed like the image below:



From the screenshot below, .133 connects to .3 for about 2041 seconds which when divided by 60 seconds per minute, we get about 34 minutes. The total packet is 166, which is considered to be relatively small for that duration. The destination port (port B) may also look suspicious since it is going to port 445, which is Server Message Block, therefore we will have to follow the stream to find out more about that specific stream.

After following the TCP stream, it turns out to be encrypted. But I tried looking at it more thoroughly, by setting up a filter in Wireshark, which is “tcp.stream == 18”, since it is what is said when we follow the TCP stream.



When I saw the packets I immediately looked for familiar names, such as:

- \srvsvc or \lsarpc - standard windows pipes
- \msagent_x - default name for cobalt strike beacons
- \status_x - often used by Metasploit framework
- \randomstring - mostly used to avoid detection for C2.

The first thing I noticed is that the Create Request File, Get Info, Tree Connect which signals that there is an initiating SMB connection.

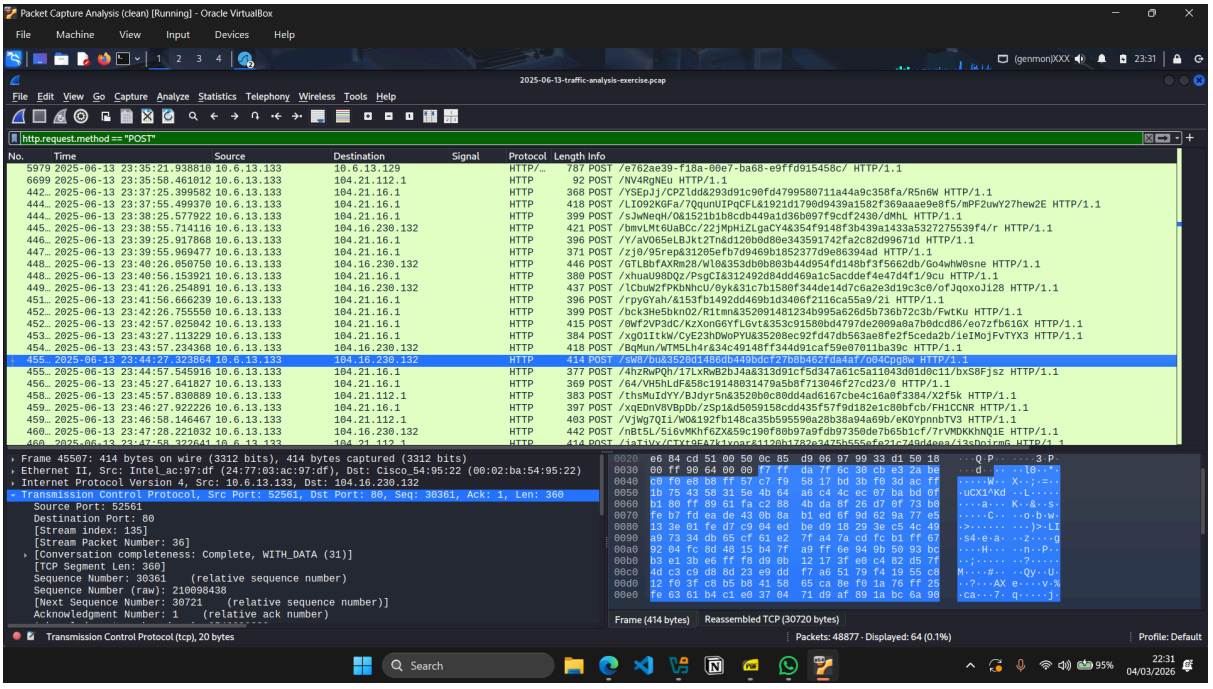
But what I found is the $Extend\$Quota directory which is a hidden directory, an important NTFS system metadata file located in the root of the drive, that stores information about users’ accounts. But then it responded with a path not found error status message.

Then it also done a Get Info request to:

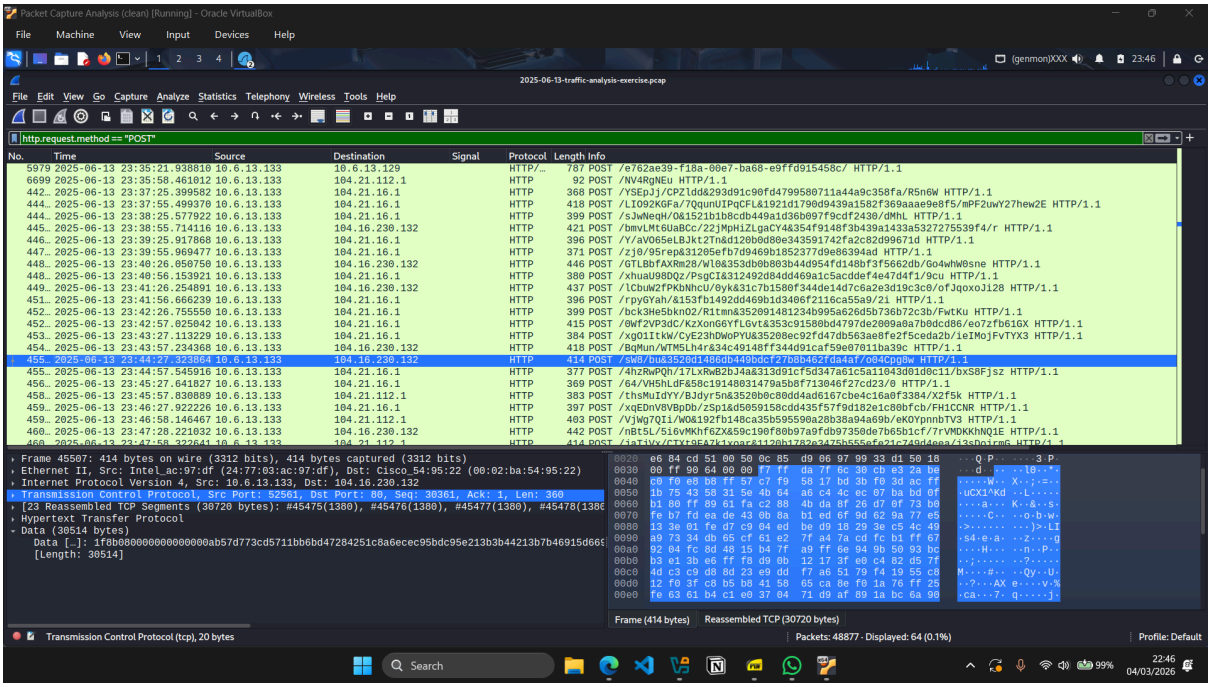
- FS_INFO/FileFsVolume Information
- FileNormalizedNameInformation

It gathers information about file attributes, file volumes, and the type of file system. So from the information we got previously, this is not a beaconing behavior. Neither it is a payload, exploit, or file upload. This shows an SMB enumeration activity. That is for now.

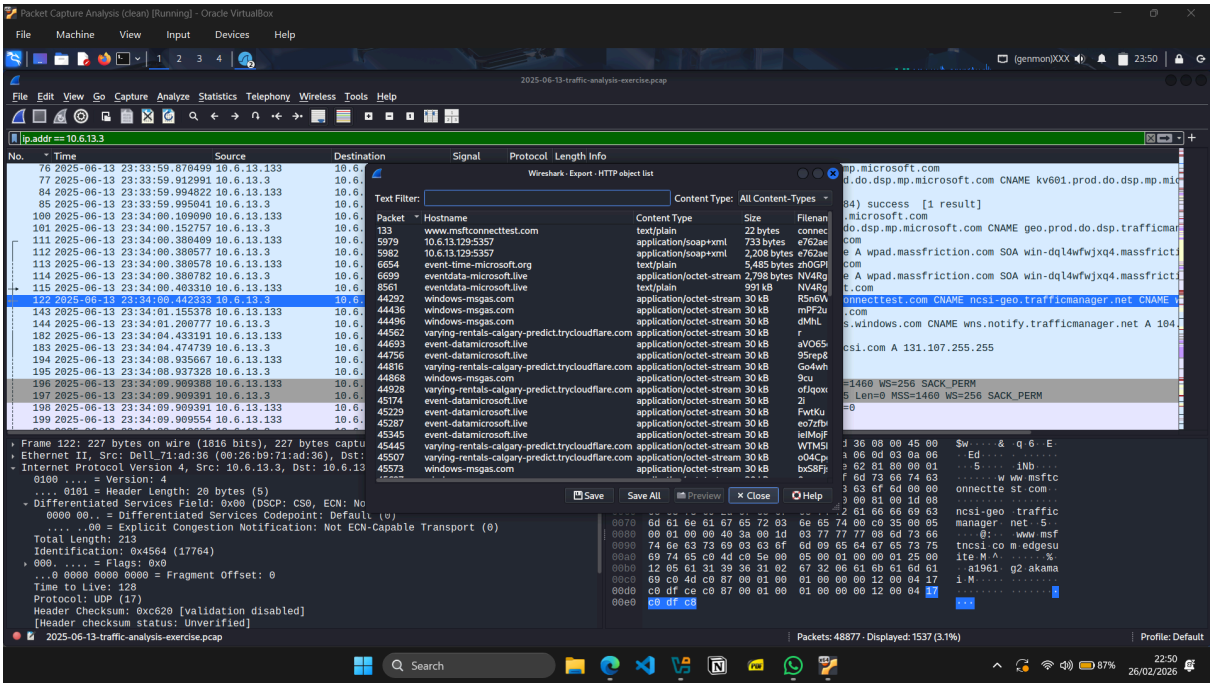
But I still want to check if there are any Beaconing or C2 activity, and then I want to filter for POST requests since C2 behavior will always be POST requests to the same IP address regularly, at an odd time interval, and similar packet sizes. And here we can see data is posted to 104.21.16.1 and 104.16.230.132. On the left side columns, on the Column of "Time", we can see the time interval is usually 30 seconds, which would indicate a C2 action.



Then I tried looking again at the packet sizes and they were similarly uniform in sizes, which usually are in the 30500s bytes. This is the confirmation already that this is a beaconing or C2 behavior.

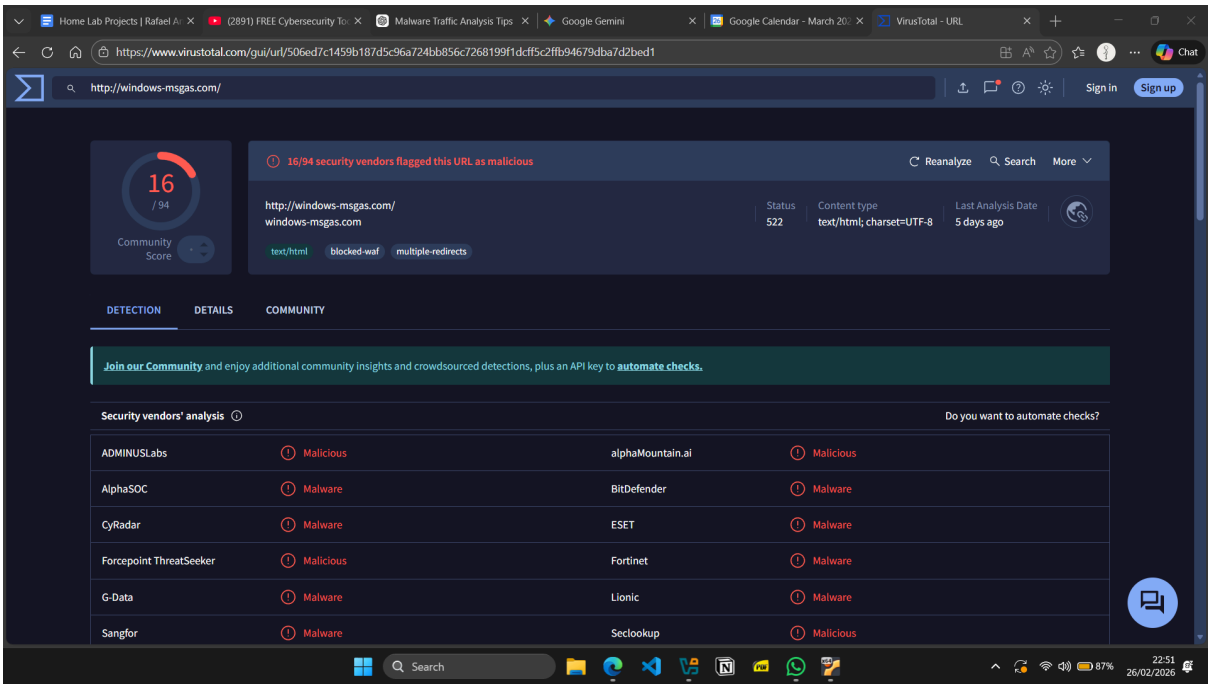


Below, I went ahead and saw the Export Objects feature from Wireshark, but I will not be saving the file as it could cause harm and damage, even though I am already working on a VM. This menu is accessible from File > Export Objects > HTTP. Therefore these files/links are associated with HTTP throughout this packet capture file. We can see several links that may look malicious that we will explore soon.

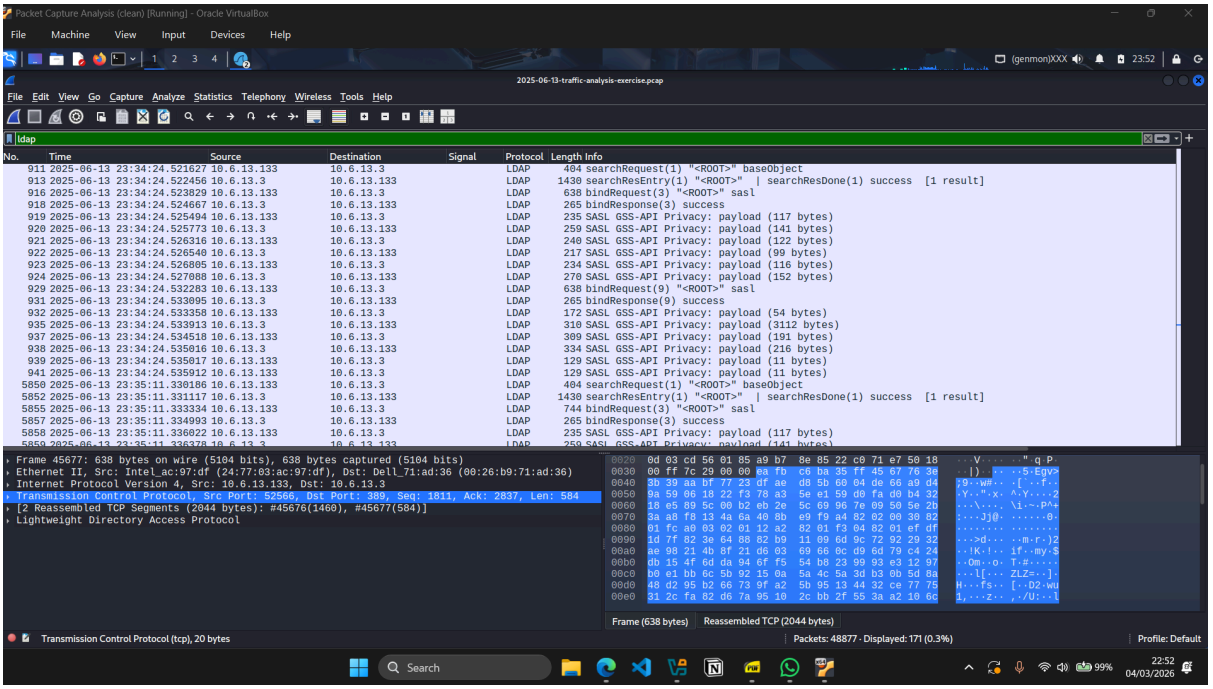


First is that of course, there is the event-time-microsoft.org that we scanned already previously. There is also microsoft-msgas.com, which does not sound or

look like a legit microsoft domain, therefore I will just scan it with Virus Total and yes it is marked as malicious.



Now I want to check for Active Directory enumeration by filtering ldap and it is happening between 10.6.13.133 and 10.6.13.3.



As we can see from the screenshot above, the client is querying the root of the directory tree, which is commonly used for the retrieval of the domain name. And the client is authenticating through LDAP through SASL (Kerberos).

But more to the bottom packets in the screenshot above, we see that the connection is encrypted with GSS-API which is a Kerberos session protection. But since I can see only a few LDAP request packets and there is only a total of 171 packets for LDAP, I have concluded that there is no DNS enumeration involved here.

Conclusion

Infected IP: 10.6.13.133
MAC: 24:77:03:ac:97:df
Hostname: DESKTOP-5AVE44C
User: rgaines
C2 Domains:

- event-time-microsoft.org
- microsoft-msgas.com

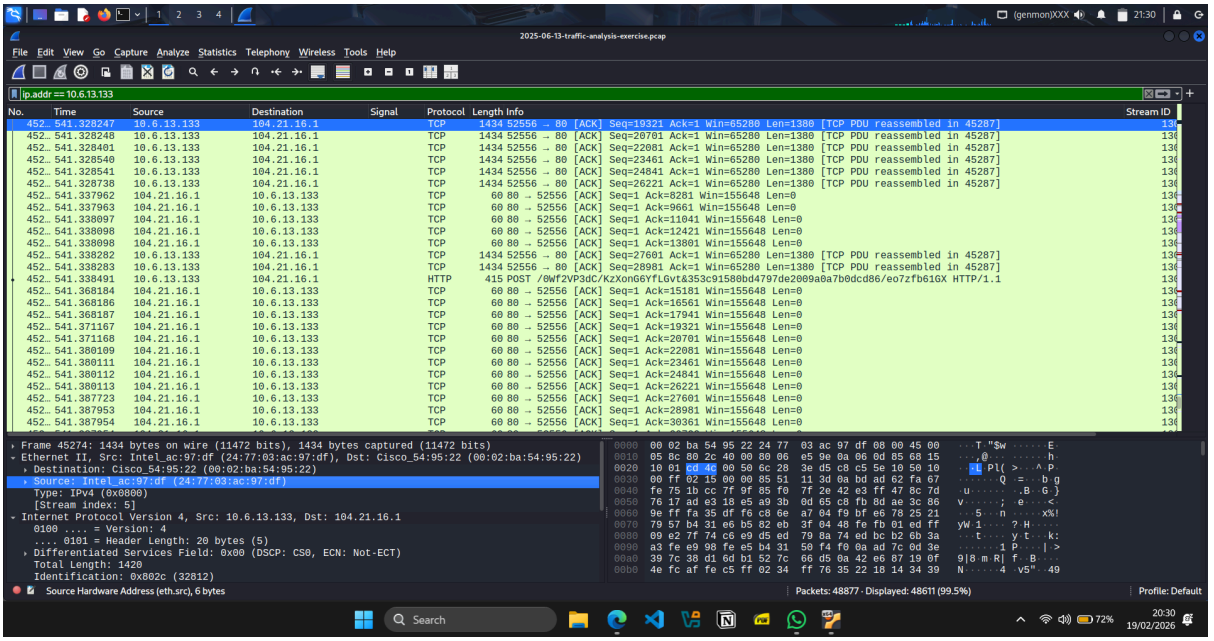
C2 IPs:

- 104.21.16.1
- 104.16.230.132

The Questions

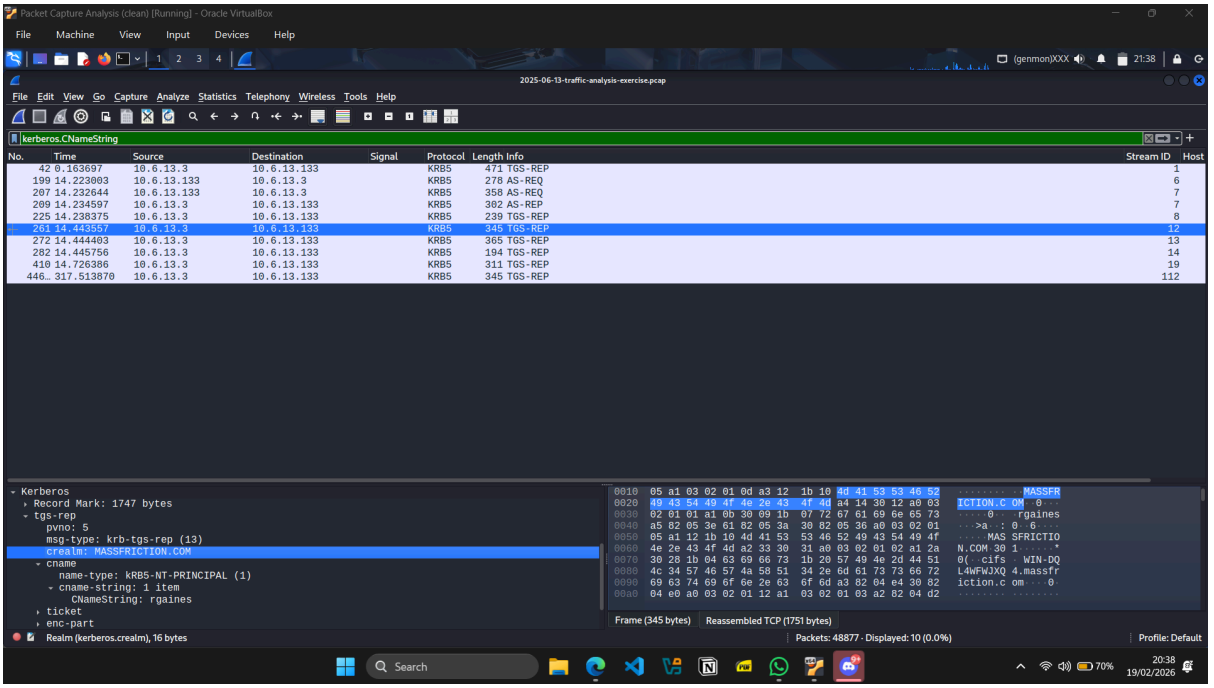
The questions below are provided by malware-traffic-analysis.net specifically to this packet capture file. There are 4 and here are the answers:

- What is the IP address of the infected Windows client?
    - Thorough the packet capture file, we can notice that 10.6.13.133 is the most targeted IP address
- What is the mac address of the infected Windows client?



- I put a filter to the IP of the infected client, which is 'ip.addr == 10.6.13.133'. And in the bottom left under the Ethernet dropdown which would indicate Layer 2, the Data Link layer. The blocked blue row indicates the MAC address of the infected client which is, 24:77:03:ac:97:df.

- What is the host name of the infected Windows client?
  - Like we have found before, by massfriction.com, the host name is DESKTOP-5AVE44C.
- What is the user account name from the infected Windows client?



- I found the username using Kerberos, which is one of the protocols to authenticate. And the syntax is ‘Kerberos.CNameString’. In the left bottom, we can see the username which is rgaines.